From Containers to Code

Applying Post-9/11 Trade Security Lessons to OSS Supply Chains

Presented by Stephanie Lieggi, University of California, Santa Cruz

at the at the OFA Symposium on November 18-19, 2025

A research collaboration by UC Santa Cruz, UC Berkeley, and Center for Nonproliferation Studies at MIIS

Acknowledgments

This on-going research is funded by

Digital Infrastructure Insights Fund

(DIIF)

We are grateful for their support in advancing research on software supply chain security and open source sustainability

Current OSS Security Landscape

Seeing increase in attacks; numbers only expected to rise.

Three Major Incidents

SolarWinds (2020)

Compromised build pipeline, 18,000 customers affected

Log4j (2021)

Zero-day vulnerability, decade-long remediation expected

XZ Utils (2024)

Social engineering, trusted maintainer compromised

Current OSS Security Landscape

Existing Tools & Frameworks

- Vulnerability databases
- Static analyzers
- Software Bills of Materials (SBOMs)
- Security standards

The Challenge

- Limited adoption
- Unclear prioritization
- Lack of integration

Regulatory Reactions

EU Cyber Resilience Act

U.S. Executive Order 14028

CISA Secure Software Attestation

The Post-9/11 Trade Security Paradigm

9/11 highlighted potential vulnerabilities in global cargo networks

Key Initiatives Developed

C-TPAT (US)

Voluntary public-private partnership

CSI

Pre-screening at foreign ports (80% of US imports)

AEO Programs

90+ countries, 18,000+ EU traders

SAFE Framework

International customs cooperation

Success Factors from Trade Security

1

Shared Urgency

Immediate post-9/11 threat perception drove coordinated action

2

Incentivization

Faster processing and reduced inspections created competitive advantage

3

Alignment with Operations

Security added to existing processes, not complete overhaul

4

Continuous Auditing

Regular validation maintained security culture over 20+ years

Physical vs Digital: Limits to Analogies

Critical Differences

Solutions must be adapted, not directly replicated

- **SBOMs =/= physical BOMs;** “no atomic unit” to OSS inventory
- **Software is dynamic;** tangible goods are static
- **No single "point of origin"** for OSS development
- **Transitive dependencies** create complexity beyond physical BOMs
- **Software replicates instantly;** physical goods do not

Applying Trade Security Lessons to OSS

Trusted Trader Programs → Project Certification

Voluntary certification with tangible benefits: liability safe harbors, procurement preferences, reduced insurance

CSI Model → Security "Upstream"

Secure at origin: integrate security from component selection through build pipeline

MRAs → Global OSS Standards

Harmonized international standards with mutual recognition across jurisdictions

C-TPAT Audits → Continuous Validation

Living documentation, automated validation, regular audits for ongoing security

Security as competitive advantage through incentives, not mandates—aligning with how development actually works

Creating Actionable Lessons for OSS Security

Incentivize Security

Liability safe harbors, procurement preferences

Push Security "Upstream"

CSI model: secure at origin (early development lifecycle)

International Standards

Harmonized global standards, MRAs for software security programs

Continuous Validation

Living documentation, automated validation, regular audits

Reframing security as competitive advantage, not friction

Proposed Framework (Work in Progress)

"Trusted Source" Programs

Tiered voluntary certification (like C-TPAT)

Multilateral Institutions

Global framework with MRAs for national programs

Investment in Maintenance

Funding for security tools & maintainer support

Shared Responsibility

Industry stewardship for critical OSS projects

Questions?

Project Team:

- Stephanie Lieggi (slieggi@ucsc.edu)
- Juanita Gomez (jgomez91@ucsc.edu)
- Robert Shaw (rashaw@middlebury.edu)
- Jarrod Millman (millman@berkeley.edu)

Special thanks to advisor Alvaro Cardenas, UCSC